

AWS IAM User Provisioning, Access Validation, Privilege Escalation, and Remediation Lab

Objective:

The purpose of this assignment is to demonstrate how AWS IAM user provisioning, Role-Based Access Control(RBAC), access validation, test privilege escalation, and remediate inside the aws cloud environment.

Environment:

1. AWS IAM
2. 3 User Accounts
3. 2 Security Groups
4. Custom IAM Policy
5. Amazon S3

Phase 1: Provisioning:

In this phase of the project, I provisioned user accounts, groups, and policies to simulate the onboarding process within an AWS IAM environment. User accounts were created and assigned to groups based on their job functions, implementing role-based access control (RBAC) principles. Permissions were assigned according to the principle of least privilege, with HR and Network users receiving only the access necessary to perform their responsibilities, while administrative S3 permissions were assigned to the S3 Admins group. A custom IAM policy was then created to introduce a controlled privilege escalation scenario for security testing purposes.

For this lab I began by creating two new user, Todd-Barkley and Caroline.

IAM users (3) Info

An IAM user is an identity with long-term credentials that is used to interact with AWS in an account.

☐	User name	Path	Groups	Last activity	MFA	Password age	Console last sign-in	Access key ID	Active key age	Access key last used
☐	Caroline	/	1	7 minutes ago	-	7 minutes	7 minutes ago	-	-	-
☐	Steve	/	1	-	-	15 minutes	-	-	-	-
☐	Todd-Barkley	/	1	-	-	58 minutes	-	-	-	-

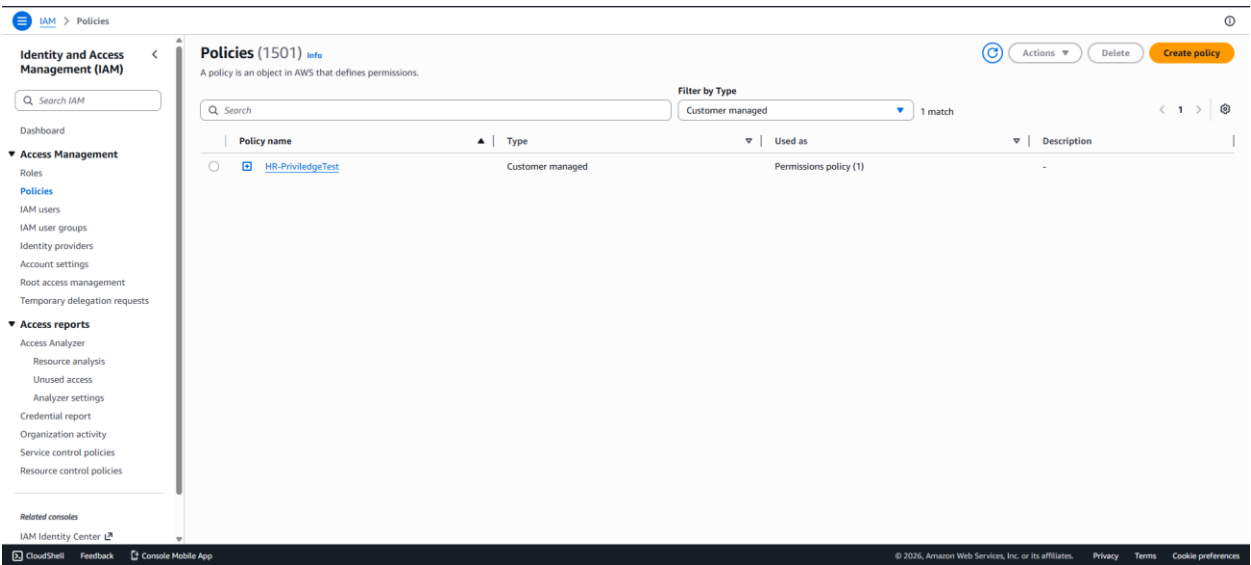
I Then created 2 new user groups and assigned the new users to the user groups to simulate assigning users to a new role that wasn't predefined before.

IAM user groups (3) Info

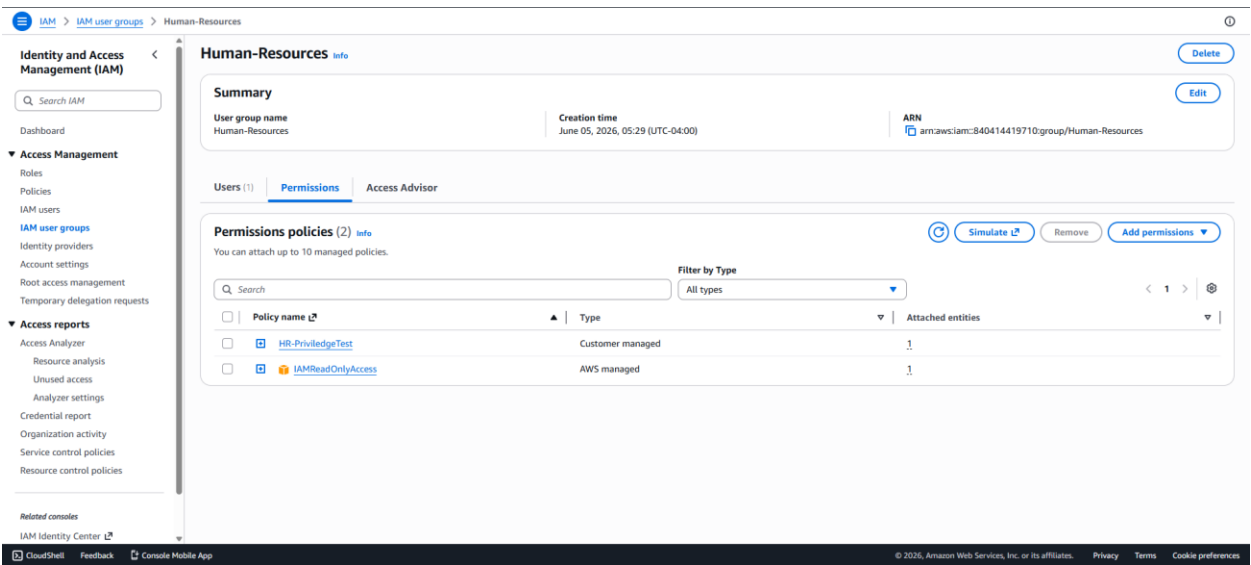
A user group is a collection of IAM users. Use groups to specify permissions for a collection of users.

☐	Group name	Users	Permissions	Creation time
☐	Human-Resources	1	Defined	42 minutes ago
☐	Network-ReadOnly	1	Defined	31 minutes ago
☐	S3-admins	1	Defined	2 years ago

To evaluate the impact of excessive permissions, a custom IAM policy was created and assigned to a test group to simulate a privilege escalation scenario



I then added the new policy into the human resources group to give users in this group the ability to assign roles.

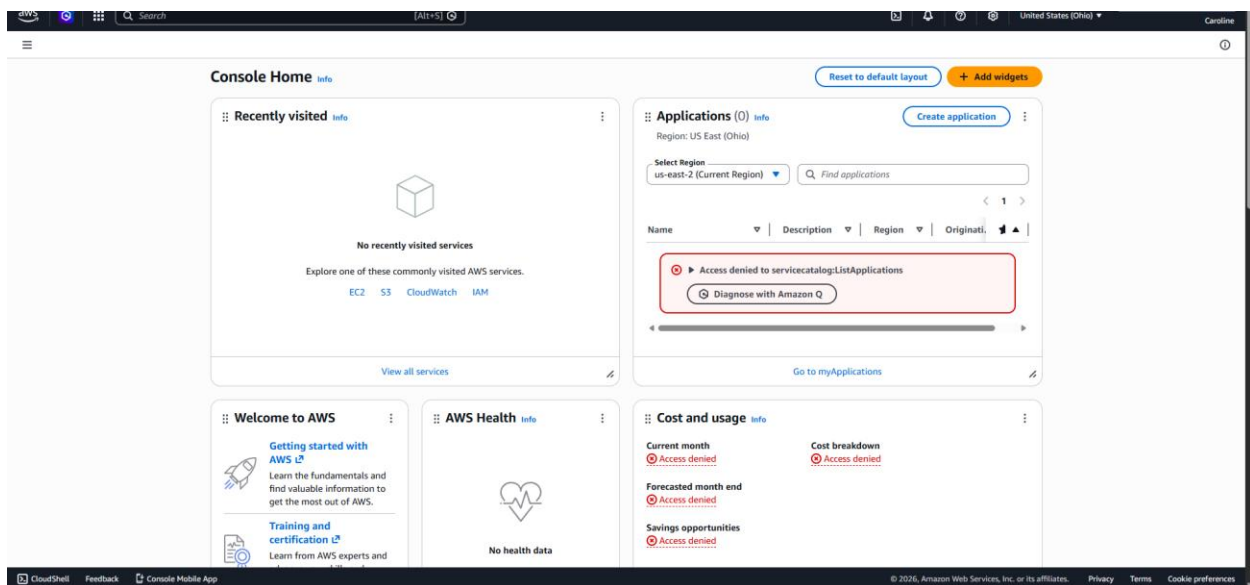


Phase 2: Access Validation & Privilege Escalation.

In this phase, I validated access for each user account and confirmed that the accounts could successfully log in. When logging in to Caroline's account for the first time, AWS prompted a password change, demonstrating a common onboarding security control. After logging in, I reviewed Caroline's permissions within IAM and confirmed that she could view IAM resources but could not create users, groups, or policies. While reviewing the assigned permissions, I discovered that the HR group policy allowed users to add members to groups. To test the impact of this permission, I added Caroline to the S3 Admins group and then verified whether elevated access to Amazon S3 had been inherited.

User account validation

Caroline:



Todd-Barkley:

The screenshot shows the AWS Management Console for user Todd-Barkley in the US East (N. Virginia) region. The interface includes a top navigation bar with the AWS logo, a search bar, and a user profile dropdown. The main content area is titled "Console Home" and features several widgets:

- Recently visited:** A list showing "IAM" as the only recently visited service.
- Applications:** A section for managing applications in the "us-east-1 (Current Region)". It displays "No applications" and a "Create application" button.
- Welcome to AWS:** A section with links for "Getting started with AWS" and "Training and certification".
- AWS Health:** A section showing "Open issues: 0", "Scheduled changes: 1", and "Other notifications: 0".
- Cost and usage:** A section showing "Current month: Access denied", "Forecasted month end: Access denied", and "Savings opportunities: Not enabled".

The bottom of the console features a footer with links to "CloudShell", "Feedback", and "Console Mobile App", along with a copyright notice for Amazon Web Services, Inc.

Steve:

The screenshot shows the AWS Management Console for user Steve in the US East (Ohio) region. The interface is similar to the one for Todd-Barkley, but with some differences in the data and widgets:

- Recently visited:** A message stating "No recently visited services" with a list of commonly visited services: "EC2", "S3", "CloudWatch", and "IAM".
- Applications:** A section for managing applications in the "us-east-2 (Current Region)". It displays an "Access denied to servicecatalog:ListApplications" error message with a "Diagnose with Amazon Q" button.
- Welcome to AWS:** A section with links for "Getting started with AWS" and "Training and certification".
- AWS Health:** A section showing "No health data".
- Cost and usage:** A section showing "Current month: Access denied", "Forecasted month end: Access denied", and "Savings opportunities: Access denied".

The bottom of the console features a footer with links to "CloudShell", "Feedback", and "Console Mobile App", along with a copyright notice for Amazon Web Services, Inc.

Caroline's s3 bucket provisioning.

s3admin group.

User was not created.
User arn:aws:iam::840414419710:user/Caroline is not authorized to perform: iam:CreateUser on resource: arn:aws:iam::840414419710:user/Stephen because no identity-based policy allows the iam:CreateUser action

Review and create
Review your choices. After you create the user, you can view and download the autogenerated password, if enabled.

User details

User name Stephen	Console password type Custom password	Require password reset Yes
----------------------	--	-------------------------------

Permissions summary

Name	Type	Used as
IAMUserChangePassword	AWS managed	Permissions policy

Tags - optional
Tags are key-value pairs you can add to AWS resources to help identify, organize, or search for resources. Choose any tags you want to associate with this user.
No tags associated with the resource.
[Add new tag](#)
You can add up to 50 more tags.

[Cancel](#) [Previous](#) [Create user](#)

User group was not created.
User arn:aws:iam::840414419710:user/Caroline is not authorized to perform: iam:CreateGroup on resource: arn:aws:iam::840414419710:group/Carolines-Friends-Who-should-get-paid-more because no identity-based policy allows the iam:CreateGroup action

Create user group

Name the group

User group name
Enter a meaningful name to identify this group.
Carolines-Friends-Who-should-get-paid-more
Maximum 128 characters. Use alphanumeric and "+-@_." characters.

Add users to the group - Optional (2/3)

An IAM user is an entity that you create in AWS to represent the person or application that uses it to interact with AWS.

User name	Group	Last activity	Creation time
☒ Caroline	1	8 minutes ago	1 hour ago
☐ Steve	1	8 minutes ago	2 years ago
☒ Todd-Barkley	1	19 minutes ago	1 hour ago

Attach permissions policies - Optional (10/1159)

You can attach up to 10 policies to this user group. All the users in this group will have permissions that are defined in the selected policies.

Filter by Type
Search: AWS managed - job function 12 matches

CloudShellFeedbackConsole Mobile App

© 2026, Amazon Web Services, Inc. or its affiliates. PrivacyTermsCookie preferences

IAM

Policies

Create policy

Failed to create policy Carolines-Master-Policy.

User arn:aws:iam:840414419710:user/Caroline is not authorized to perform: iam:CreatePolicy on resource: policy Carolines-Master-Policy because no identity-based policy allows the iam:CreatePolicy action

Diagnose with Amazon Q

Step 1

Specify permissions

Step 2

Review and create

Review and create

Review the permissions, specify details, and tags.

Policy details

Policy name

Enter a meaningful name to identify this policy.

Carolines-Master-Policy

Maximum 128 characters. Use alphanumeric and '+', '-', '@', '_', '.' characters.

Description - optional

Add a short explanation for this policy.

a policy for me who can do everything an IAM can do because IAM better than the whole AIM team.

Maximum 1,000 characters. Use alphanumeric and '+', '-', '@', '_', '.' characters.

Permissions defined in this policy

Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it

Search

Allow (1 of 470 services)

Show remaining 469 services

Service	Access level	Resource	Request condition
IAM	Full access	All resources	None

The image consists of two screenshots from the AWS IAM console. The top screenshot shows the 'Add users to S3-admins' page. It features a search bar and a table of users. The bottom screenshot shows the 'S3-admins' group page with a summary and a list of users.

Top Screenshot: Add users to S3-admins

Other users in this account (1/2)

User name	Groups	Last activity	Creation time
☒ Caroline	1	14 minutes ago	1 hour ago
☐ Todd-Barkley	1	24 minutes ago	1 hour ago

Buttons: Cancel, Add users

Bottom Screenshot: S3-admins

Summary

User group name	Creation time	ARN
S3-admins	July 07, 2023, 18:35 (UTC-04:00)	arn:aws:iam::840414419710:group/S3-admins

Buttons: Delete, Edit

Users (2)

An IAM user is an entity that you create in AWS to represent the person or application that uses it to interact with AWS.

User name	Groups	Last activity	Creation time
☐ Caroline	2	14 minutes ago	1 hour ago
☐ Steve	1	15 minutes ago	2 years ago

Buttons: Remove, Add users

Following successful privilege escalation, access to Amazon S3 was validated to determine the operational impact of the newly acquired permissions. Caroline was able to view the premade s3 bucket but also created their own bucket(folders) and add objects(files) to the

buckets.

Amazon S3 > Buckets > elasticbeanstalk-us-east-2-840414419710

elasticbeanstalk-us-east-2-840414419710 info

Objects (3)

Objects are the fundamental entities stored in Amazon S3. You can use [Amazon S3 inventory](#) to get a list of all objects in your bucket. For others to access your objects, you'll need to explicitly grant them permissions. [Learn more](#)

Name	Type	Last modified	Size	Storage class
elasticbeanstalk	elasticbeanstalk	July 14, 2023, 12:22:00 (UTC-04:00)	0 B	Standard
1689351716031-tomcat.zip	zip	July 14, 2023, 12:21:58 (UTC-04:00)	8.3 KB	Standard
resources/	Folder	-	-	-

Amazon S3 > Buckets > hr-s3-access-test

Successfully created bucket "hr-s3-access-test"

hr-s3-access-test info

Objects (0)

Objects are the fundamental entities stored in Amazon S3. You can use [Amazon S3 inventory](#) to get a list of all objects in your bucket. For others to access your objects, you'll need to explicitly grant them permissions. [Learn more](#)

No objects

You don't have any objects in this bucket.

Upload

Amazon S3

Upload

Caroline

Upload

Info

Add the files and folders you want to upload to S3. To upload a file larger than 160GiB, use the AWS CLI, AWS SDKs or Amazon S3 REST API. [Learn more](#)

Drag and drop files and folders you want to upload here, or choose [Add files](#) or [Add folder](#).

Files and folders (1 total, 617.9 KB)

RemoveAdd filesAdd folder

All files and folders in this table will be uploaded.

Find by name

☐	Name	Folder	Type	Size
☐	CyberSecurityResume w.docx	-	application/vnd.openxmlformats-officedocument.wo...	617.9 KB

Destination

Info

Destination

s3://hr-s3-access-test

Destination details

Bucket settings that impact new objects stored in the specified destination.

Permissions

Grant public access and access to other AWS accounts.

Properties

Specify storage class, encryption settings, tags, and more.

Cancel

Upload

Amazon S3

Upload: status

Caroline

Upload succeeded

For more information, see the [Files and folders](#) table.

Upload: status

Close

After you navigate away from this page, the following information is no longer available.

Summary

Destination

s3://hr-s3-access-test

Succeeded

1 file, 617.9 KB (100.00%)

Failed

0 files, 0 B (0%)

Files and folders

Configuration

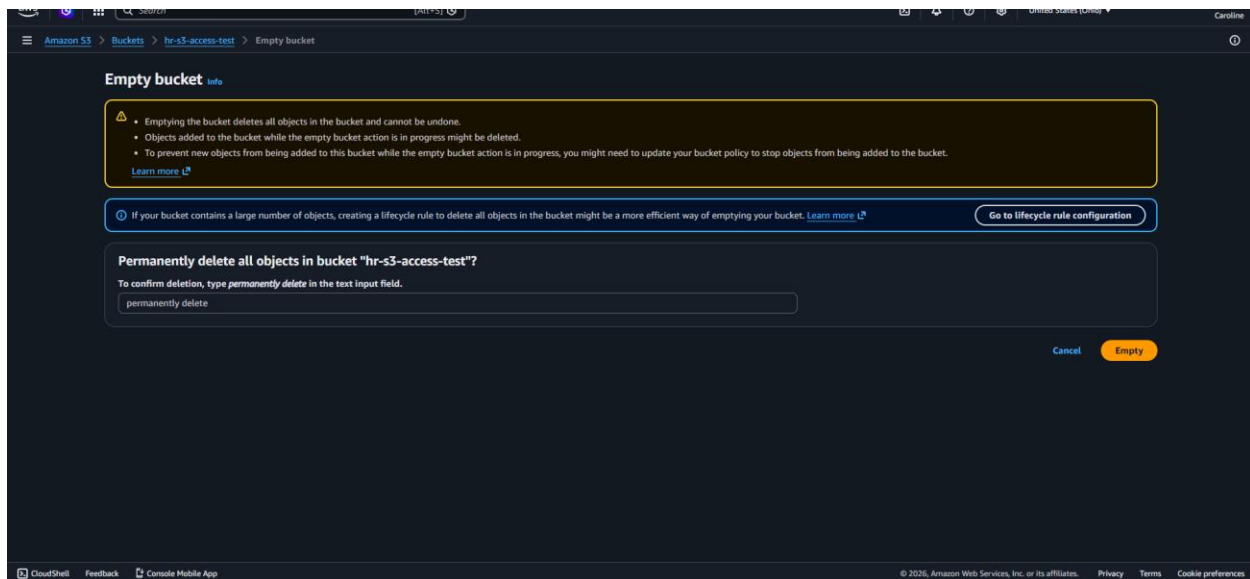
Files and folders (1 total, 617.9 KB)

Find by name

Name	Folder	Type	Size	Status	Error
CyberSecurityResume w.docx	-	application/vnd.openxmlformats...	617.9 KB	Succeeded	-

Phase3: Remediation

In the remediation phase I removed the test objective from the s3 bucket and then deleted the bucket. After cleaning up the created resources, I removed Caroline from the S3admin group to revoke the elevated permissions. I then removed the custom IAM policy from the human resource group and deleted the policy entirely to restore the path of least privilege and prevent further unauthorized privilege escalation.



CloudShellFeedbackConsole Mobile App

© 2026, Amazon Web Services, Inc. or its affiliates. PrivacyTermsCookie preferences

Amazon S3Buckets>hr-s3-access-test>Delete bucket

United States (Ohio)Caroline

Delete bucket [Info](#)

⚠

Deleting a bucket cannot be undone.

- Bucket names are unique. If you delete a bucket, another AWS user can use the name.
- If this bucket is used with a Multi-Region Access Point in an external account, initiate failover before deleting the bucket.
- If this bucket is used with an access point in an external account, the requests made through those access points will fail after you delete this bucket.

[Learn more](#)

Delete bucket "hr-s3-access-test"?

To confirm deletion, enter the name of the bucket in the text input field.

hr-s3-access-test

CancelDelete bucket

CloudShellFeedbackConsole Mobile App

© 2026, Amazon Web Services, Inc. or its affiliates. PrivacyTermsCookie preferences

Amazon S3Buckets

United States (Ohio)Caroline

Successfully deleted bucket "hr-s3-access-test"

Buckets

General purpose bucketsAll AWS RegionsDirectory buckets

General purpose buckets (1) [Info](#)

Copy ARNEmptyDeleteCreate bucket

Buckets are containers for data stored in S3.

Find buckets by name

Name	AWS Region	Creation date
elasticbeanstalk-us-east-2-840414419710	US East (Ohio) us-east-2	July 14, 2023, 12:20:50 (UTC-04:00)

Account snapshot [Info](#)

Updated daily

View dashboard

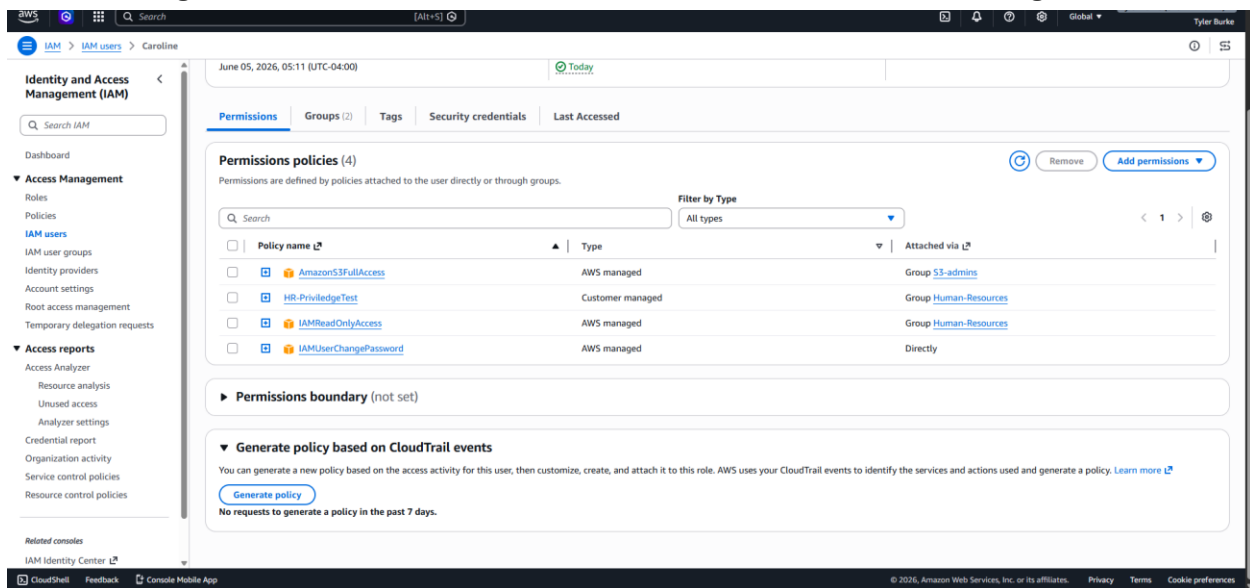
Storage Lens provides visibility into storage usage and activity trends.

External access summary [Info](#)

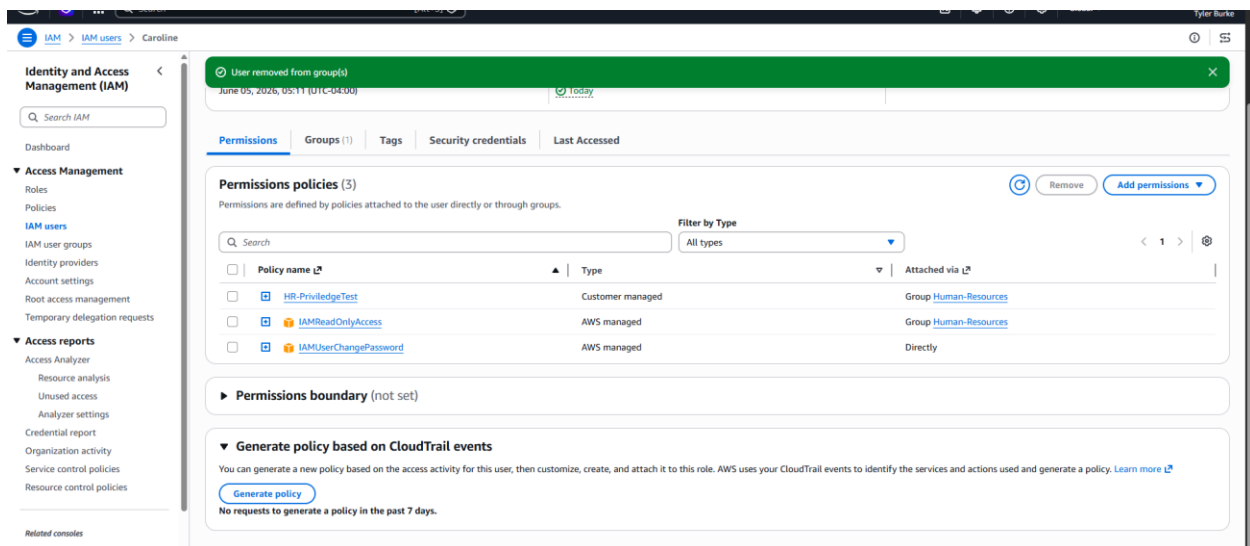
Updated daily

External access findings help you identify bucket permissions that allow public access or access from other AWS accounts.

After deleting the bucket I switched back to the root user account to investigate what



I see that she has 4 permissions now, 1 being s3admin which I removed from her account, however one of the hr policies seemed interesting so I investigated further.



In the Human-Resource group I found that the one policy shouldn't be there as this allows users to elevate their privilege, I then removed that policy from the user group to sanitize

and make sure no other human-resource employees can privilege creep.

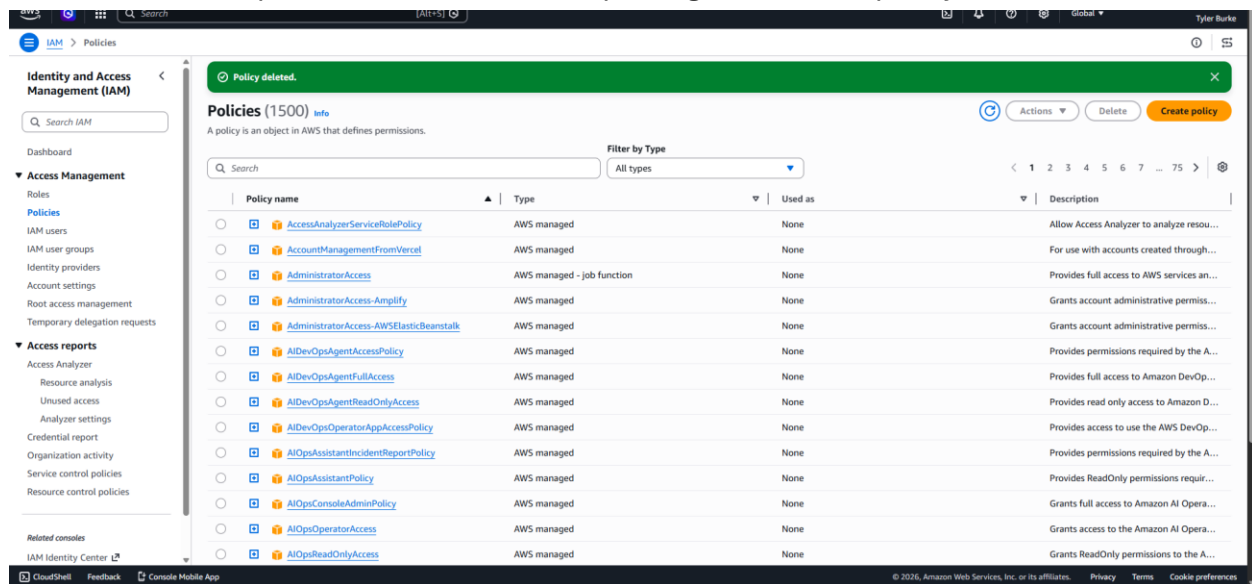
The screenshot shows the AWS IAM console interface. On the left is a navigation sidebar with sections for Identity and Access Management (IAM), Access Management, and Access reports. The main content area is titled 'Human-Resources' and includes a 'Summary' section with details like 'User group name', 'Creation time', and 'ARN'. Below this is a 'Permissions policies (2)' section with a table listing attached policies: 'HR-PrivilegeTest' (Customer managed) and 'IAMReadOnlyAccess' (AWS managed). Buttons for 'Simulate', 'Remove', and 'Add permissions' are visible.

Policy name	Type	Attached entities
HR-PrivilegeTest	Customer managed	1
IAMReadOnlyAccess	AWS managed	1

This screenshot shows the same AWS IAM console page after a policy has been removed. A green banner at the top of the main content area displays the message 'Policy removed.' The 'Permissions policies (1)' section now only lists 'IAMReadOnlyAccess' (AWS managed). The 'Summary' section and navigation sidebar remain the same as in the previous screenshot.

Policy name	Type	Attached entities
IAMReadOnlyAccess	AWS managed	1

I then entered the policies tab to delete the privilege escalation policy.



Lessons Learned:

This project reinforced the importance of Role-Based Access Control (RBAC) and the principle of least privilege within an AWS IAM environment. While Caroline was unable to create new users, groups, or policies, she was able to escalate her privileges by adding herself to the S3 Admins group through a misconfigured permission. This demonstrated how a single excessive permission can lead to significantly expanded access and increased risk to cloud resources.

Through the remediation phase, I gained experience identifying the source of excessive permissions, removing unauthorized access, and restoring intended security controls. The project also highlighted the importance of regular access reviews and policy audits to prevent privilege creep and maintain a secure IAM environment.